Simulazione di phishing a tema Trenitalia

Luca Calzia - 3/11/2026

1 Obiettivo

L'obiettivo è riconoscere i meccanismi dell'ingegneria sociale e valutare il contributo dell'IA nella preparazione e nell'analisi di un messaggio sospetto. Trenitalia è la società reale scelta per lo scenario.

Il lavoro comprende lo scenario, il testo dimostrativo, l'analisi degli indicatori e le misure di difesa. Non comprende l'invio della campagna, una pagina di raccolta dati o una prova con destinatari reali. Non sono quindi disponibili tassi di apertura, clic o segnalazione.

2 Concetti di riferimento

Il social engineering sfrutta fiducia, aspettative ed emozioni per indurre una persona a compiere un'azione. Il phishing applica questo meccanismo a messaggi che si presentano come comunicazioni di un soggetto affidabile. Lo spear phishing è invece mirato a un destinatario o gruppo specifico e utilizza informazioni pertinenti al suo contesto.

3 Scenario progettato

Elemento	Descrizione
Destinatari ipotizzati	Persone che utilizzano il treno
Identità impersonata	Assistenza clienti Trenitalia
Pretesto e canale	Presunto rimborso comunicato tramite email
Azione sollecitata	Aprire una pagina per verificare la pratica
Leve utilizzate	Fiducia nel marchio, vantaggio economico e urgenza

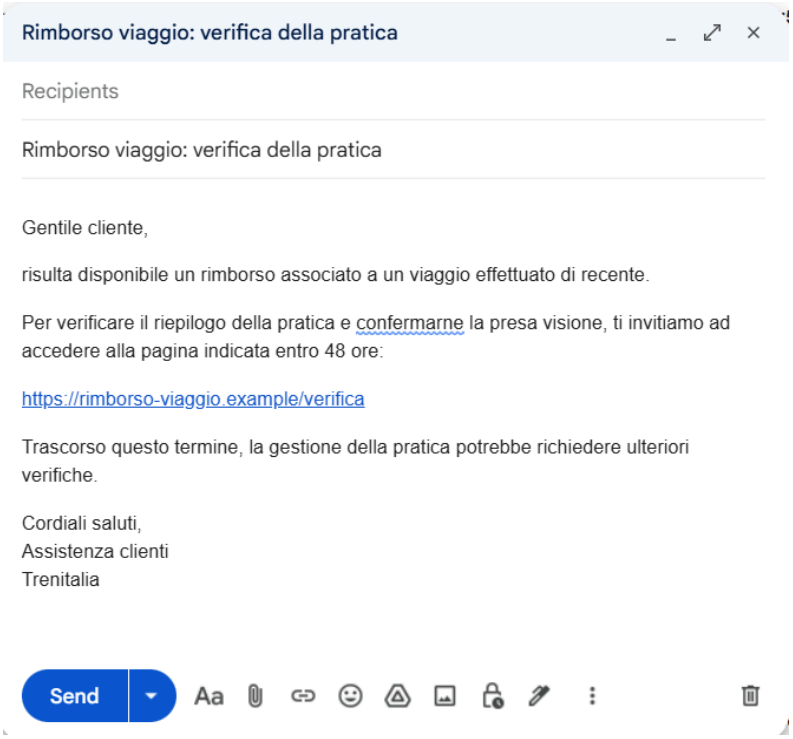
4 Impiego dell’intelligenza artificiale

Nel lavoro preparatorio l’IA è stata utilizzata per proporre scenari, adattare l’esempio alla società scelta e discutere gli indicatori di rischio. Il risultato è una bozza ragionata, sottoposta ad analisi qualitativa. Per riprodurre l’impostazione si può utilizzare il seguente prompt, che definisce contesto, contenuto e limiti della simulazione.

Prompt di generazione

«Per un’esercitazione didattica sul social engineering, prepara un esempio simulato di email di phishing che impersona Trenitalia e comunica un presunto rimborso. Usa un tono formale, una scadenza e un collegamento segnaposto con dominio .example. Non richiedere password, codici o dati di pagamento. Specifica separatamente che il messaggio non rappresenta una comunicazione o procedura autentica della società. Identifica poi i meccanismi psicologici utilizzati.»

5 Email dimostrativa



Gli indirizzi con dominio *.example* sono segnaposto dimostrativi. L’esempio non contiene una pagina operativa e non richiede l’inserimento di dati. La pagina è rappresentata soltanto dal collegamento indicato nel testo.

6 Analisi del messaggio

La valutazione distingue gli elementi osservabili dalle interpretazioni. Nessun singolo indicatore, preso isolatamente, consente di stabilire se una comunicazione è autentica, ci sarebbe bisogno di una verifica prima di agire.

Il riferimento a un viaggio recente può sembrare comune a chi utilizza il treno, pur senza dimostrare che il mittente abbia una prenotazione reale.

La correttezza grammaticale non autentica l'email. Anche il solo uso di HTTPS non dimostra che un sito appartenga alla società dichiarata: la valutazione deve riguardare identità, destinazione e contenuto della richiesta.

7 Seconda analisi assistita proposta

Per un controllo aggiuntivo è stata definita la seguente istruzione:

Prompt di analisi:

«Analizza questa email come possibile phishing. Esamina mittente, collegamento, richiesta e pressione psicologica. Separa fatti e ipotesi, non inventare procedure di Trenitalia e indica verifiche indipendenti. Non assegnare percentuali di autenticità prive di dati verificabili».



Analizza questa email come possibile phishing. Esamina mittente, collegamento, richiesta e pressione psicologica. Separa fatti e ipotesi, non inventare procedure di Trenitalia e indica verifiche indipendenti. Non assegnare percentuali di autenticità prive di dati verificabili

Ha lavorato per 28s ›

Il testo presenta segnali compatibili con il phishing, ma lo screenshot non dimostra una truffa effettivamente ricevuta. Mostra una finestra di composizione, con pulsante "Send" e destinatari vuoti: possiamo analizzare il contenuto, ma non verificarne provenienza e invio.

Elemento	Fatti osservabili	Interpretazione e limiti
Mittente	La firma riporta "Assistenza clienti Trenitalia". Non sono visibili indirizzo del mittente o intestazioni tecniche.	Il nome dell'azienda può suggerire autorevolezza, ma una firma non autentica il mittente. Non possiamo affermare che l'indirizzo sia falso o contraffatto.
Collegamento	Il testo visibile è `https://rimborso-viaggio.example/verifica`.	`.example` è riservato agli esempi e alla documentazione: questo è coerente con una simulazione, non prova l'esistenza di un sito criminale. Dall'immagine non possiamo verificare se la destinazione effettiva coincida con il testo mostrato.
Richiesta	Si invita ad accedere a una pagina per verificare una pratica e confermare la presa visione. Mancano importo, data del viaggio, tratta e riferimento della pratica.	La genericità rende difficile riscontrare il rimborso. Il collegamento potrebbe introdurre una successiva raccolta di dati, ma nel testo non vengono richiesti password, dati bancari o pagamenti.
Pressione psicologica	Compare il termine "entro 48 ore", seguito dalla possibilità di "ulteriori verifiche".	Il rimborso offre un incentivo economico; la scadenza spinge ad agire rapidamente; il richiamo a complicazioni può scoraggiare controlli. Non viene però dichiarata la perdita del rimborso.

Cosa rimane un'ipotesi

È plausibile che il testo sia costruito per indurre un clic sfruttando fiducia nel marchio, aspettativa di un rimborso e urgenza. Non è dimostrato che dietro il collegamento esistano una pagina contraffatta, malware o un sistema di furto delle credenziali. Anche l'uso di HTTPS, da solo, non certifica l'identità di chi gestisce un sito.

Verifiche indipendenti

1. **Aprire autonomamente il sito Trenitalia**, digitando `www.trenitalia.com`, **oppure utilizzare l'app** ufficiale già installata. Confrontare il messaggio con i propri viaggi ed eventuali richieste di rimborso.
2. **Contattare l'assistenza usando recapiti reperiti sul sito ufficiale**, chiedendo conferma dell'esistenza della pratica e della scadenza indicata. La pagina Informazioni e assistenza raccoglie i canali di assistenza e le informazioni sui rimborsi.
3. **Se esiste un'email ricevuta originale, esaminare indirizzo completo, Reply-To e intestazioni**, inclusi i risultati SPF, DKIM e DMARC. Questi controlli aiutano a valutare la provenienza tecnica, senza garantire da soli la legittimità della richiesta.
4. **Controllare la destinazione del collegamento senza aprirlo**, tramite l'anteprima dell'indirizzo o l'analisi del messaggio originale.

Valutazione: contenuto sospetto da verificare prima di interagire; screenshot coerente con un esempio didattico. Non ci sono elementi sufficienti per confermare un attacco reale né per attribuire percentuali di autenticità. La presunta procedura delle "48 ore" resta un'affermazione del messaggio, non una procedura Trenitalia verificata.

8 Contromisure individuate

Il destinatario dovrebbe prima verificare la richiesta utilizzando informazioni dal sito ufficiale.

- Controllare se si attende un rimborso e se la richiesta è coerente con un viaggio realmente effettuato.
- Aprire autonomamente l'app o il sito ufficiale e cercare informazioni pertinenti alla propria pratica.
- Contattare l'assistenza mediante i recapiti pubblicati sul sito ufficiale, senza usare numeri o risposte suggeriti dall'email sospetta.
- Evitare di comunicare password, codici temporanei o dati di pagamento in risposta a una richiesta non verificata.
- Usare la funzione di segnalazione del servizio di posta o la procedura prevista dalla propria organizzazione.

9 Conclusione

Il caso evidenzia come una richiesta apparentemente ordinaria possa sfruttare aspettative e fiducia per sollecitare un'azione. L'IA ha contribuito alla costruzione e alla discussione dell'esempio; il controllo umano resta necessario per distinguere fatti, ipotesi e informazioni non verificate. La risposta difensiva individuata consiste nel confermare la richiesta tramite canali ufficiali raggiunti autonomamente.